

Гальцев Алексей Анатольевич

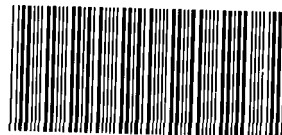
**СИСТЕМНЫЙ АНАЛИЗ ТРАФИКА
ДЛЯ ВЫЯВЛЕНИЯ АНОМАЛЬНЫХ СОСТОЯНИЙ СЕТИ**

05.13.01 – Системный анализ, управление и обработка
информации (технические системы и связь)

Автореферат
диссертации на соискание ученой степени
кандидата технических наук

14 МАР 2013

Самара – 2013



005050603

Работа выполнена в ФГБОУ ВПО «Самарский государственный аэрокосмический университет имени академика С.П.Королёва (национальный исследовательский университет)».

Научный руководитель:

доктор технических наук Сухов Андрей Михайлович

Официальные оппоненты:

Елизаров Александр Михайлович, доктор физико-математических наук, профессор, Институт математики и механики имени Н.И.Лобачевского ФГАОУ ВПО «Казанский (Приволжский) федеральный университет», заместитель директора по научной деятельности;

Лихтциндер Борис Яковлевич, доктор технических наук, профессор, ФГБОУ ВПО «Поволжский государственный университет телекоммуникаций и информатики», кафедра мультисервисных систем и информационной безопасности, профессор.

Ведущая организация - ФГАУ «Государственный научно-исследовательский институт информационных технологий и телекоммуникаций» (г. Москва)

Защита диссертации состоится 5 апреля 2013 г. в 10-00 часов на заседании диссертационного совета Д 212.215.07, созданного на базе ФГБОУ ВПО «Самарский государственный аэрокосмический университет имени академика С.П.Королёва (национальный исследовательский университет)», по адресу: 443086, г. Самара, Московское шоссе, д. 34.

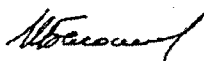
С диссертацией можно ознакомиться в библиотеке ФГБОУ ВПО «Самарский государственный аэрокосмический университет имени академика С.П.Королёва (национальный исследовательский университет)».

Автореферат разослан 4 марта 2013 г.

Ученый секретарь

диссертационного совета,

доктор технических наук профессор



Белоконов И.В.

Общая характеристика работы

Актуальность темы

Задача анализа трафика магистральных Интернет-каналов с каждым годом становится все более востребованной. На данный момент всемирная сеть Интернет используется не только для обмена информацией, но и для предоставления различных услуг, в том числе государственных. Тем самым остро встает вопрос об обеспечении отказоустойчивой, бесперебойной работы серверов организаций, предоставляющих такие услуги.

Анализ трафика магистральных Интернет-каналов является сложной задачей, зависящей от множества параметров, которая с трудом поддается декомпозиции и моделированию. Одной из причин этого является постоянное усложнение структуры глобальной сети, которая характеризуется взаимодействием большого количества устройств самых разных типов, которые не имеют единого центра управления.

Для организации взаимодействия в неоднородной сетевой среде применяется стек протоколов TCP/IP, который обеспечивает совместимость между компьютерами и сетевыми компонентами разных архитектур. Данный стек протоколов приобрел популярность благодаря универсальности предоставления доступа к сети Интернет, в результате чего стал стандартом для межсетевое взаимодействия. Вместе с тем широкое распространение набора протоколов TCP/IP выявило и его недостатки.

Интернет-протоколы изначально были разработаны таким образом, что в них не была включена защита от непредвиденных сбоев и неправильных сетевых настроек, а также умышленных вторжений в инфраструктуру сетей. По этой причине сетевым атакам подвержены распределённые системы на базе глобальной сети, так как компоненты таких систем, как правило, применяют открытые каналы передачи данных. В результате нарушитель получает возможность проводить пассивное прослушивание передаваемых данных, но и модифицировать пересылаемый трафик. С другой стороны, безусловно работающие сервисы с негарантированной доставкой данных, как было предусмотрено при создании Интернет, не являются ни достаточным для многих из современных интерактивных приложений реального времени, ни приемлемым для все более требовательных пользователей. Как следствие, операторы должны осуществлять мониторинг и контроль состояния сети на постоянной основе в целях обеспечения надлежащего функционирования, выявления и устранения сетевых аномалий, а также повышения качества обслуживания.

Несанкционированные вторжения в сетевую инфраструктуру являются сегодня одной из основных угроз для современной сети Интернет. Трудность выявления несанкционированных вторжений и относительная простота их реализации выводит данный вид правонарушений на одно из первых мест по степени опасности. Несвоевременное обнаружение препятствует оперативному

реагированию на проводимое вторжение, вследствие чего у нарушителя увеличиваются шансы успешного осуществления атаки.

В настоящей работе основное внимание сосредоточено на вопросе разработки модели трафика для выявления аномальных состояний сети и противодействия сетевым вторжениям. Наиболее актуальной задачей является поиск методов защиты от DDoS-атак, поскольку до сих пор не разработано средств, позволяющих полностью защитить удаленные ресурсы от данного вида деструктивного вмешательства в работу компьютерной сети и ее отдельных узлов. DDoS-атаки являются простыми в реализации, что делает их наиболее распространенным видом сетевых вторжений. В течение 2011 года были зафиксированы масштабные атаки на такие крупные ресурсы, как блог-платформа LiveJournal, платежная система PayPal, сайт радиостанции «Эхо Москвы» и другие организации, в результате которых сервисы на долгое время оказались неработоспособными. Эти события говорят о необходимости разработки новых методов своевременного обнаружения и предотвращения несанкционированных вторжений.

Вопросы моделирования трафика магистральных Интернет-каналов, а также обнаружения и предотвращения несанкционированных вторжений, в разное время исследовали С. Barakat, С. Fraleigh, М. Fullmer, А.А. Долгин, Е.Л. Дружинин и др.

В связи с этим актуальной представляется разработка моделей трафика, методов и алгоритмов, позволяющих в течение короткого времени обнаруживать аномальные состояния сети и принять меры по их устранению.

Результаты исследования соответствуют пунктам 4 – «Разработка методов и алгоритмов решения задач системного анализа, оптимизации, управления, принятия решений и обработки информации», 5 – «Разработка специального математического и программного обеспечения систем анализа, оптимизации, управления, принятия решений и обработки информации» паспорта научной специальности 05.13.01 – Системный анализ, управление и обработка информации (технические системы и связь).

Объект исследования – трафик магистральных Интернет-каналов.

Предмет исследования – процесс выявления аномальных состояний сети на магистральных Интернет-каналах.

Цель и задачи исследований.

Целью работы является разработка модели, методов, позволяющих выявить системные связи и закономерности Интернет трафика для выявления аномальных состояний сети и предотвращения несанкционированных вторжений.

В соответствии с поставленной целью в рамках диссертационной работы решаются следующие задачи исследования.

1. Провести обзор существующих моделей трафика и методов по выявлению аномальных состояний сети.

2. Провести исследование системных связей трафика на уровне агрегированных состояний сети (потоков) и разработать модель трафика.
3. Разработать метод обнаружения аномальных состояний сети путем обработки информации о потоках по критериям предложенной модели трафика.
4. Разработать методику отбора внешних IP-адресов, с которых может происходить несанкционированное вторжение.
5. Разработать комплекс программно-аппаратных средств, блокирующий несанкционированный доступ к защищаемой сети.

Научная новизна работы

В диссертации получены следующие новые научные результаты.

1. Предложена модель Интернет-трафика на уровне потоков, которая впервые предлагает описывать текущее состояние сети двумя переменными: загрузкой сети и числом активных потоков, – в отличие от других моделей, использующих только один параметр (загрузка сети).
2. Получено уравнение для рабочей области на плоскости сетевых состояний, последовательный выход за пределы которой двух или более состояний свидетельствует об аномальном функционировании сети.
3. Экспериментально доказано, что разработанная модель трафика позволяет регистрировать аномальные состояния сети в течение нескольких минут после начала внешнего воздействия.
4. Разработана новая методика определения IP-адресов, с которых производится несанкционированное вторжение, которая заключается в многократном росте активных потоков, генерируемых IP-адресом.

Реализация результатов работы

Результаты диссертационной работы внедрены и используются для защиты от сетевых вторжений компьютерной сети Самарского государственного аэрокосмического университета имени С.П. Королева, хостинга ООО НПЦ «Интернет-ТВ» и сайта региональной службы новостей www.samara.ru.

Основные результаты получены в рамках следующих проектов.

1. «Разработка сетевых информационных технологий параллельной и распределенной обработки данных, электронного обучения и интернет-телевещания», выполняемый в рамках Федеральной целевой программы «Научные и научно-педагогические кадры инновационной России» на 2009-2013 годы» (ГК П2234 от 11 ноября 2009 г.).
2. «Разработка и реализация в учебном процессе и научных исследованиях инновационных информационных технологий и подготовка методических материалов по использованию суперкомпьютерной и инфокоммуникационной GRID-среды СГАУ» (ГК ОК 07/11).

По теме диссертации опубликованы 8 работ, в том числе 3 в изданиях, рекомендованных ВАК.

Апробация работы

Основные результаты, связанные с разработкой модели трафика на уровне потоков и программно-аппаратного комплекса, докладывались на следующих конференциях: XVI конференции представителей региональных научно-образовательных сетей «RELARN-2009» (2 – 7 июня 2009, Москва - Санкт-Петербург, Теплоход «Александр Суворов»); XVI Всероссийская научно-методическая конференция «Телематика 2009» (22 – 25 июня 2009, Санкт-Петербург); Всероссийская молодежная научная конференция с международным участием «Королёвские чтения» (6 – 8 октября 2009, Самара); The 11th International Conference on Next Generation Wired/Wireless Networking NEW2AN 2011 (23 – 25 August 2011, St. Petersburg).

Основные положения диссертации, выносимые на защиту

1. Модель трафика на уровне потоков, содержащая сетевые переменные, измеряемые на маршрутизаторах.
2. Метод обнаружения аномальных состояний сети.
3. Методика обнаружения IP-адресов, с которых ведется несанкционированное вторжение двух типов: DDoS и сканирование портов.
4. Алгоритмы поиска и блокирования источников несанкционированного вторжения.

Структура и объем работы

Диссертация состоит из введения, четырех глав, заключения, списка литературы и приложения. Общий объем работы составляет 116 страниц, 26 рисунков, 5 таблиц. Библиографический список насчитывает 102 наименования.

Содержание работы

Во введении обоснована актуальность работы, сформулированы ее цель и задачи. Проведен обзор известных методов решения задач обнаружения и предотвращения сетевых атак. Приводятся перечень научных результатов и положения, выносимые на защиту.

В первой главе проводится анализ современного состояния решения проблемы выявления аномальных состояний компьютерных сетей.

Рассмотрены особенности существующих решений и результаты проводимых исследований, приводится классификация наиболее распространенных сетевых аномалий. Особое внимание уделяется классификации аномалий и описанию их возможных проявлений по характеристикам сетевого трафика. Наибольшее внимание уделяется сетевым вторжениям и их характеристикам. Изучение данных атак относительно деструктивного воздействия на компьютерные сети и системы,

позволило выделить следующие основные группы: сканирование, вирусная активность, отказ в обслуживании, сетевые модификаторы, анализаторы трафика, эксплуатация уязвимостей.

На основе проведенного анализа исследованы основные методические подходы и системы обнаружения сетевых вторжений. В частности, рассмотрены системы обнаружения и предотвращения сетевых вторжений и их основные особенности. Данные системы в совокупности позволяют обнаружить многие типы сетевых атак. Кроме того, функциональность систем обнаружения и предотвращения вторжений частично перекрывается. Но, к сожалению, даже все они вместе взятые не позволяют полностью решить проблему целиком. Например, подавляющее большинство таких систем, как IDS (Intrusion Detection Systems – системы предотвращения вторжений), способны обнаруживать только известные типы аномалий. Реализованные в некоторых из них алгоритмы выявления неизвестных аномалий дают высокий процент ложных срабатываний.

Основными результатами исследования, проведенного в первой главе, являются сформированная классификация основных типов сетевых аномалий и анализ основных методических подходов и систем обнаружения и предотвращения сетевых вторжений. На основе проведенного анализа делается вывод о целесообразности разработки новой модели трафика, методов и алгоритмов выявления аномальных состояний сети. Сформулирована постановка задачи и частные задачи исследования.

Во второй главе приводится обзор существующих подходов к описанию магистрального Интернет трафика. Проводится анализ существующих моделей на предмет их применения к задачам обнаружения сетевых аномалий, и в частности сетевых вторжений. Рассмотрены два подхода к моделированию трафика: основанные на представлении трафика в виде пакетов и потоков. Показано, что потоковые модели трафика оказываются более производительными и масштабируемыми, требуя при этом намного меньших затрат по обработке данных по сравнению с пакетными моделями. Потоковые технологии (NetFlow) были созданы компанией Cisco для учета сетевого трафика и оперируют с агрегированными состояниями сети, называемыми потоками (flow), характеризующимися семью неизменными сетевыми параметрами, среди которых основными являются IP-адреса и порты отправителя и получателя данных.

Предлагаемая модель Интернет-трафика описывает текущее состояние сети двумя переменными: загрузкой канала $B(t)$ и числом активных потоков $N(t)$. Данная модель основана на модели магистрального трафика, построенной Чади Баракатом и др. в 2002 г. с использованием методов теории массового обслуживания. Его модель позволяет предсказывать поведение средней величины загрузки канала и ее дисперсии за короткие промежутки времени с помощью трех параметров:

- λ - постоянная прибытия потоков (поток/с), описывает поведение пользователей сети и не зависит от состояния сети или ее загрузки;
- $M[S_n]$ - среднее значение размера потока S_n (бит);

- $M[S_n^2/V_n]$ - среднее значение отношения квадрата размера потока S_n к его длительности V_n (бит²/с).

Используя данные параметры были найдены значения следующих величин:

- среднее значение суммарной скорости B (бит/с):

$$M[B] = \lambda \cdot M[S_n]; \quad (1)$$

- дисперсия суммарной скорости B (поток-бит²/с²):

$$D[B] = \lambda \cdot M[S_n^2/V_n]. \quad (2)$$

Поскольку суммарная нагрузка исследуемого канала есть результат мультиплексирования большого количества потоков, независимых друг от друга, распределение суммарной нагрузки стремится к нормальному (Гауссову) распределению. Теоретическая модель позволяет оценить пределы, в которых будет лежать величина суммарного трафика:

$$M[B(t)] - A(\varepsilon) \cdot \sqrt{D[B(t)]} \leq B(t) \leq M[B(t)] + A(\varepsilon) \cdot \sqrt{D[B(t)]}, \quad (3)$$

где $A(\varepsilon)$ - нормальная квантильная функция.

При повседневной эксплуатации сетей измерить значения параметров, входящих в уравнение (1) и (2) достаточно проблематично. Поэтому для обнаружения сетевых аномалий с помощью модели Бараката она должна быть модернизирована, новые переменные (загрузка $B(t)$, число активных потоков $N(t)$) модели должны легко измеряться при помощи сетевого оборудования.

Для того, чтобы в уравнении (3) перейти к новым переменным модели, воспользуемся уравнением Литтла:

$$N = \lambda \cdot M[V_n], \quad (4)$$

а также теоремами о моментах. Тогда получим:

$$D[B] = \lambda \cdot (M[S_n^2] + D[S_n]) \cdot M\left[\frac{1}{V_n}\right] = \lambda \cdot M[S_n] \cdot M\left[\frac{S_n}{V_n}\right] \cdot \left(1 + \frac{D[S_n]}{M^2[S_n]}\right), \quad (5)$$

где $M[S_n/V_n] = b$ - средняя скорость потока. Обозначим выражение $\sqrt{1 + \frac{D[S_n]}{M^2[S_n]}} =$

α . Величина α является постоянной для конкретной сети и не зависит от ее текущего состояния.

В итоге уравнение для границ рабочей области на плоскости сетевых состояний может быть представлено как:

$$B(t) = b \cdot (N(t) \pm \alpha \cdot A(\varepsilon) \cdot \sqrt{N(t)}), \quad (6)$$

Значения величин α и b находится из анализа экспериментальных данных.

Таким образом, предлагается рассматривать число активных потоков $N(t)$ в качестве второй характеристики сетевого состояния. Две переменные, число активных потоков $N(t)$ и загрузка канала $B(t)$, наиболее полно описывают текущее сетевое состояние. Данные о сетевых состояниях представлены отдельными точками на координатной плоскости, где по осям отложены число активных потоков и загрузка канала (рисунок 1). На рисунке 1 кроме отдельных состояний

сети изображены еще 2 объекта: рабочая область сети и кривая усредненных значений состояний сети для исследуемой конфигурации сети.

Для построения кривой усредненных значений необходимо разбить на небольшие интервалы область значений для числа активных потоков в канале. Первая часть такой кривой представляет собой прямолинейный отрезок. Он соответствует эксплуатационному участку сети и характеризуется минимальными потерями IP-пакетов, менее 0,5%. Этот отрезок описывается первым членом уравнения (6). Уравнение (6) говорит о том, что реальные состояния сети будут находиться вне пределов рабочей области в $(1-\varepsilon) \cdot 100\%$ от общего времени наблюдения. Рабочая область определена только для эксплуатационного участка и ограничена ветвями параболы на рисунке 1.

Вторая, изогнутая часть кривой усредненных состояний соответствует перегруженной сети и характеризуется более существенными потерями пакетов до 5%, что приводит к снижению эффективного размера передаваемого сегмента ТСР/Р. В этой области эксплуатировать сеть не рекомендуется, требуется расширение внешнего канала. Третий, почти горизонтальный, участок кривой соответствует полностью неработоспособной сети со значительной потерей пакетов свыше 5%.

$B(t)$, бит/с

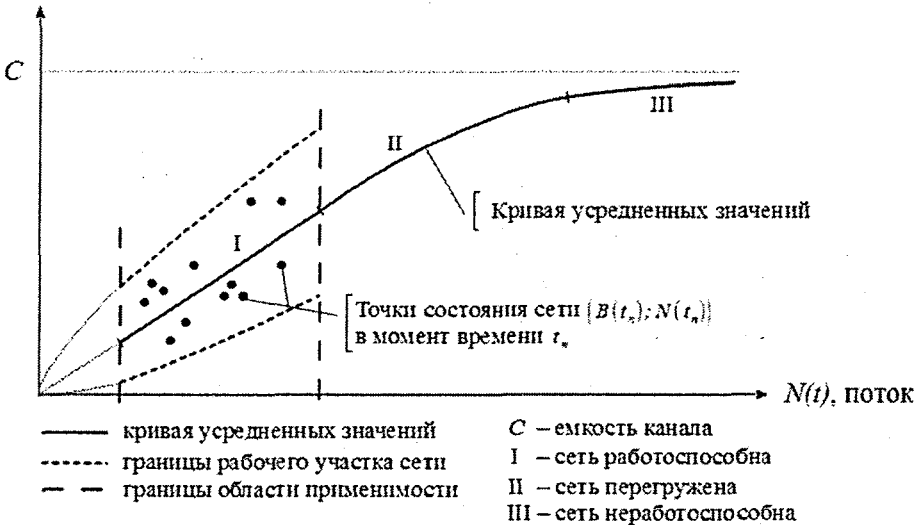


Рисунок 1 – Область состояний сети

На рисунке 2 изображены аномальные состояния сети, зафиксированные во время проведения мониторинга сети FREEnet. Полученные данные сразу вышли за

пределы доверительного интервала и образовали отдельный кластер значений, как это показано на рисунке 2.

При осуществлении сетевого вторжения состояние сети окажется вне рабочей области. Сетевые вторжения типа DDoS и сканирование портов характеризуются тем, что каждая атакующая машина создает одновременно множество соединений к атакуемому узлу. Таким образом, во время атаки происходит резкое увеличение числа активных потоков. При этом состояние сети, которое описывает предлагаемая модель, окажется вне рабочей области сетевых состояний.

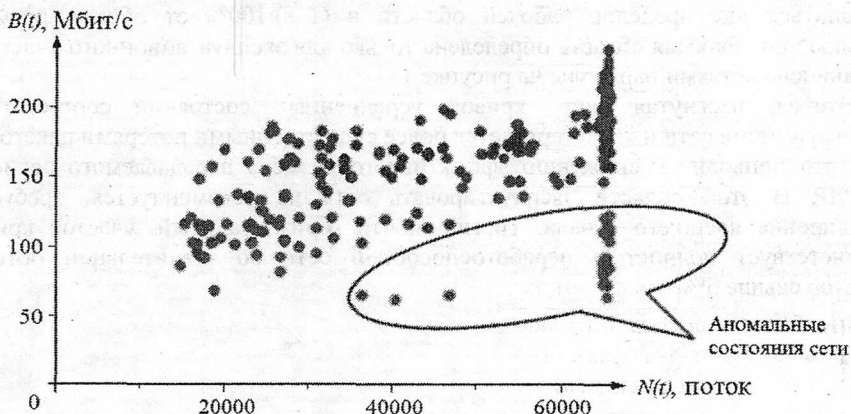


Рисунок 2 — График состояний сети

Третья глава посвящена экспериментальной проверке разработанной модели трафика на применимость для задач обнаружения аномальных состояний сети и сетевых атак различных типов. Данная проверка состоит из следующих этапов:

1) проверка модели трафика на уровне потоков с целью подтверждения зависимости формы рабочей области от переменных модели;

2) тестирование модели на возможность выявления сетевых вторжений двух типов: сканирование портов и DDoS-атаки.

Для того чтобы проверить высказанные предположения о структуре трафика и его свойствах были проведены эксперименты на граничных маршрутизаторах. Сбор данных о загрузке сети и количестве активных потоков проводился при помощи протокола NetFlow. Эксперименты были проведены на маршрутизаторах обслуживающих внешние каналы крупных сетей — академической научно-образовательной сети FREENet, ирландской научно-образовательной сети HEAnet, а также ЗАО «СамараТелеком». Скорости данных подключений составляли 1 Гбит/с для FREENet, 622 и 155 Мбит/с для HEAnet и 8 Мбит/с для СамараТелеком. Загрузка каналов варьировалась от 5% до 60% от емкости канала.

Полученные сетевые характеристики были разведены по интервалам, внутри

каждого интервала были найдены средние значения и вариации основных величин. Эти данные сведены в Таблицу 1.

В Таблице 1 N_{cp} – это среднеинтервальное значение числа активных потоков, B_{cp} представляет собой среднюю загрузку маршрутизатора в Мбит/с (Мегабит в секунду), b – средняя скорость потока, а $\sigma(B)$ это среднеквадратичные отклонение для загрузки.

Таблица 1 – Статистические тесты. Сеть FREEnet, маршрутизатор 1

n	Границы интервала	N_{cp} , поток	B_{cp} , Мбит/с	$\sigma(B)$, Мбит/с	b , бит/с	α	χ^2 для $\alpha_x=0,95$	Критерий Пирсона	Коэффициент корреляции
1	15000 – 20000	17489	113,15	23,12	6784	$16,3 \pm 3,1$	–	–	0,7
2	20000 – 25000	23260	126,05	21,41	5682		–	–	
3	25000 – 30000	27145	141,63	37,91	5471		–	–	
4	30000 – 40000	34361	150,70	26,85	4599		3,49 (9,49)	+	
5	40000 – 50000	44751	155,93	27,61	3655		–	–	
6	50000 – 60000	54591	165,18	18,53	3173		3,45 (7,81)	+	
7	> 60000	64862	191,98	20,39	3104		0,5 (9,49)	+	

Кривая с рисунка 3, равно как и данные о средней скорости потока, наглядно демонстрируют тот факт, что область эксплуатации сети выходит за пределы рабочего (прямолинейного) участка сети. Средняя скорость на поток в пределах рабочего участка (первые три точки) составляет порядка 5700 бит/с. Иными словами, исследуемая сеть нуждалась в расширении емкости основных магистральных каналов.

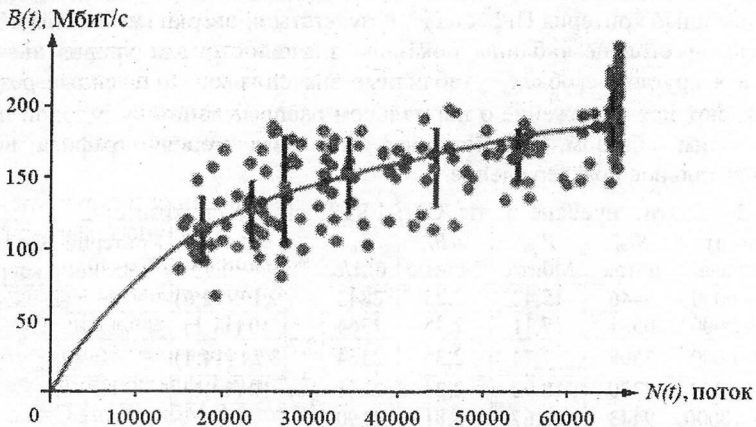


Рисунок 3 – График состояний сети FREEnet, маршрутизатор 1

На рисунке 4 приведен график состояний сети для второго маршрутизатора FREEnet. Для проверки параболической формы рабочего интервала вычислен коэффициент корреляции между значениями $\sigma_i(B)$ и $\sqrt{N_i}$, где i – номер интервала. Для первого и второго маршрутизатора коэффициенты корреляции равны соответственно 0,7 и 0,93. Это позволяет сделать вывод о высокой корреляции между теоретической моделью и данными, полученными в результате эксперимента. Данные для второго маршрутизатора сети FREEnet приведены в Таблице 2.

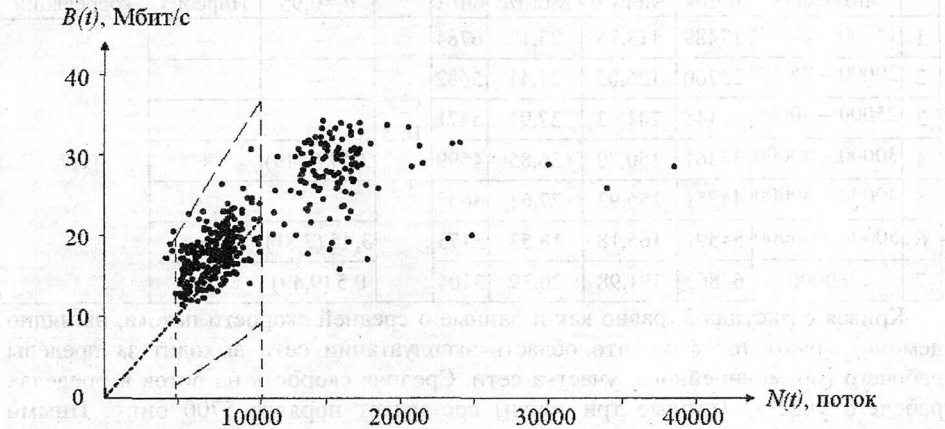


Рисунок 4 – График состояний сети FREEnet, маршрутизатор 2

Также была проведена проверка на нормальное распределение нагрузки на поток с помощью критерия Пирсона χ^2 . Результаты проверки приведены в Таблице 1. В восьмом столбце таблицы показаны значения χ^2 для уровня значимости $\alpha_x=0,95$, а в круглых скобках – табличные значения χ^2 . Полученные результаты подтверждают предположение о нормальном распределении суммарной нагрузки канала. Таким образом, предложенная потоковая модель трафика получила экспериментальное подтверждение.

Таблица 2 – Статистические тесты. Сеть FREEnet, маршрутизатор 2

n	Границы интервала	N_{cp} , поток	B_{cp} , Мбит/с	$\sigma(B)$, Мбит/с	b , бит/с	α	χ^2 для $\alpha_x=0,95$	Критерий Пирсона	Коэффициент корреляции
1	5000 – 6000	5446	15,42	2,25	2843	$5,7 \pm 1,2$	9,15 (12,6)	+	
2	6000 – 7000	6531	17,11	2,45	2364		10 (11,1)	+	
3	7000 – 8000	7508	17,74	2,35	2364		3,24 (14,1)	+	
4	8000 – 9000	8370	18,92	2,24	2261		10 (14,1)	+	
5	9000 – 10000	9443	20,67	3,81	2190		–	–	
6	> 10000	15495	28,05	5,40	1811		1,94 (14,1)	+	

На следующем этапе проведения экспериментальной проверки трафика было выяснено, можно ли применить данную модель для обнаружения сетевых вторжений. Были проведены эксперименты, имитирующие попытки атак. Они проводились на сети Самарского государственного аэрокосмического университета (СГАУ). В качестве источника атаки использовались удаленные компьютеры, подключенные к сети Интернет. Целью атаки являлся один из внутренних серверов сети СГАУ. В качестве NetFlow-сенсора был выбран пограничный маршрутизатор сети СГАУ Cisco 6509, NetFlow-коллектор — тот же сервер, который подвергался атаке.

В результате анализа данных, собранных во время сканирования сети, было выявлено резкое увеличение числа активных потоков при практически неизменном количестве переданного трафика. Каждый компьютер, осуществляющий сканирование сети, создавал в течение 5 минут порядка 10-20 тысяч потоков минимального размера (44 байт).

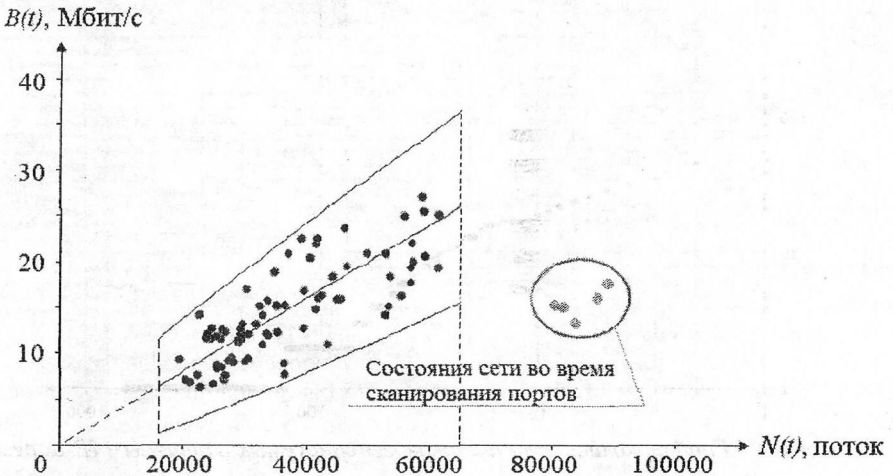


Рисунок 5 – График состояний сети во время проведения сканирования портов

Анализ эксперимента по моделированию DDoS-атаки утилитой LOIC также показал резкое увеличение числа активных потоков наряду с увеличением передаваемого трафика. Утилита параллельно отсылает данные на разные порты цели, создавая тем самым большое количество коротких потоков длительностью до минуты.

В результате стало очевидным, что предлагаемая потоковая модель трафика позволяет выявить не только момент начала атаки, но и определить ее тип.

Таким образом, рост числа активных потоков является главным признаком несанкционированного вторжения. Этот принцип можно применить и к идентификации IP-адресов, с которых проводится атака. Для поиска критериев по

определению источников атаки был проведен сбор данных NetFlow-статистики о завершившихся потоках с маршрутизатора СГАУ каждую минуту в течение нескольких суток.

Оказалось, что данный метод позволяет найти количество потоков с IP-адреса, при превышении которого можно утверждать, что с данного адреса началось несанкционированное вторжение. Полученные результаты изображены графически на рисунках 6 и 7.

Для каждого набора данных построен ранжированный список (в порядке убывания) количества потоков, генерируемых единичными IP-адресами (рисунок 6). По этому набору данных определялось максимальное количество потоков, создаваемых одним IP-адресом.

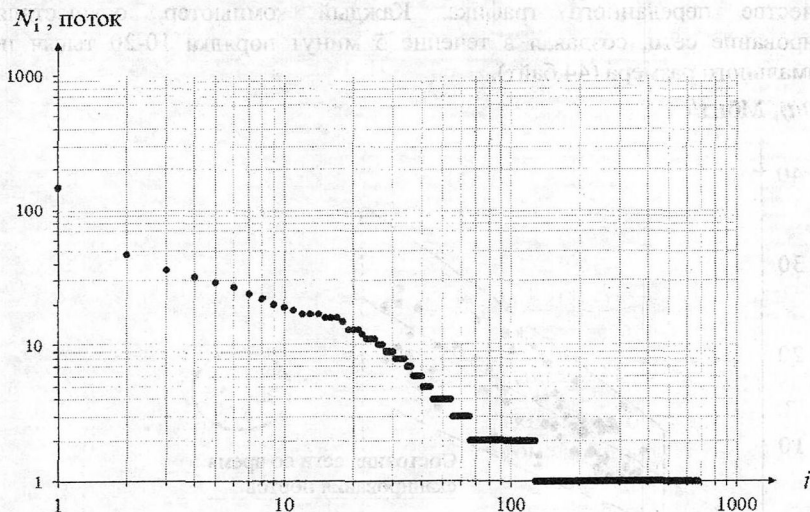


Рисунок 6 – График количества потоков, генерируемых единичным IP-адресом

В четвертой главе приводится описание разработанного комплекса программно-аппаратных средств, который реализует защищенное информационное пространство для размещения Интернет-ресурсов. Данный комплекс основан на предложенной модели трафика на уровне потоков.

Разработанные алгоритмы реализованы в виде программно-аппаратного комплекса, установленного в одном из сегментов сети СГАУ, на веб-хостинге интернет-трансляций. Данный комплекс включает в себя следующие программные компоненты:

- 1) NetFlow-коллектор nfdump, принимающий данные с граничного маршрутизатора сети СГАУ Cisco 6509;
- 2) скрипт по анализу NetFlow-данных, принятых коллектором nfdump;

3) брандмауэр iptables, блокирующий IP-адреса атакующих компьютеров, обнаруженные в результате анализа NetFlow-данных;

4) база данных MySQL, в которую заносятся IP-адреса атакующих компьютеров.

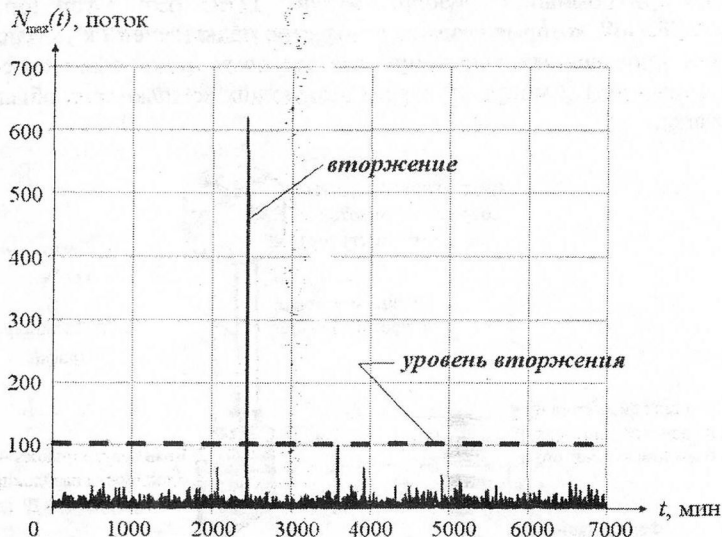


Рисунок 7 – Максимальное количество потоков с одного IP-адреса

Основой данного комплекса является скрипт на языке Perl, который установлен на защищаемом сервере. Каждую минуту скрипт получает с граничного маршрутизатора сети СГАУ файл с данными о потоках. Эти данные обрабатываются в соответствии с алгоритмами обнаружения атаки, описанными в предыдущей главе. На выходе скрипт выдает список подозрительных IP-адресов, с которых предположительно осуществляется атака. Структурная схема программно-аппаратного комплекса представлена на рисунке 8.

Подозрительные IP-адреса заносятся в базу данных и весь трафик с этих адресов блокируется брандмауэром iptables. При необходимости защиту можно распространить до масштабов всей сети СГАУ, блокируя подозрительные IP-адреса на граничном маршрутизаторе. В ближайшее время планируется исследовать возможности протокола NetFlow по обнаружению DDoS-атак, при проведении которых используется комбинация из нескольких базовых видов атак.

Для проверки работоспособности разработанного программно-аппаратного комплекса по обнаружению IP-адресов атакующих компьютеров, с которых производится DDoS-атаки, и их последующему блокированию было проведено тестирование в виде пробных DDoS-атак, максимально приближенных к реальным.

Для того, чтобы пробные атаки были похожи на реальные, они проводились с нескольких компьютеров, расположенных географически в различных местах, а также для их проведения были использованы специальные программы, предназначенные специально для осуществления подобных атак. Атаки проводились при помощи следующих утилит: LOIC (Low Orbit Ion Cannon), Slowloris HTTP-DoS, которые создают множество подключений к указанной цели. В результате проведенных испытаний все тестовые атаки были своевременно выявлены в течение 1-2 минут, IP-адреса атакующих компьютеров обнаружены и заблокированы.

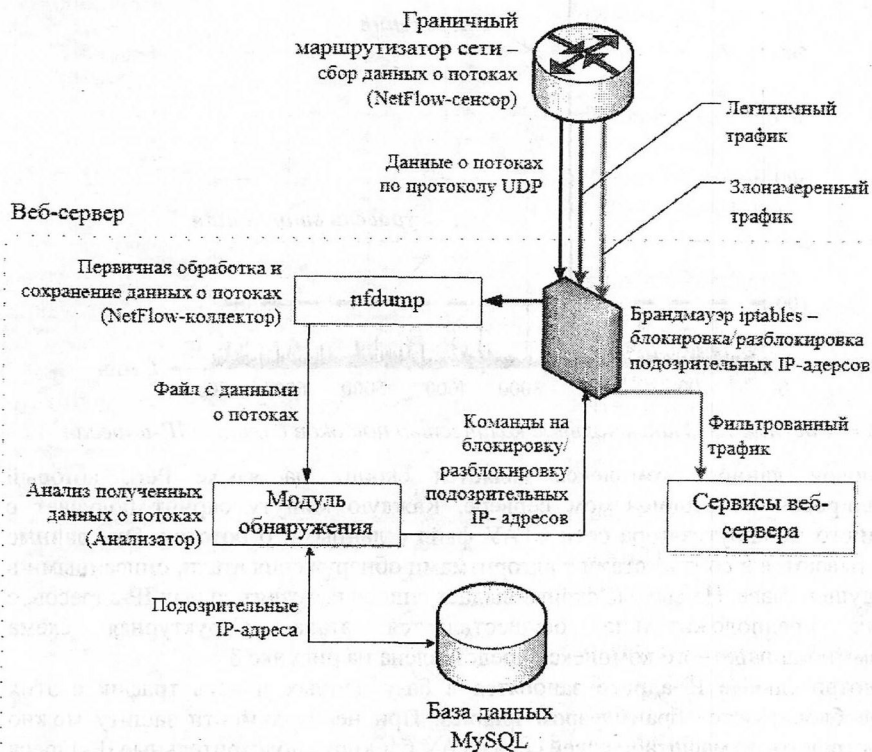


Рисунок 8 – Функциональная схема программно-аппаратного комплекса

Существующие методы противодействия DDoS-атакам основаны на анализе пакетной информации. NetFlow технология была разработана для задач биллинга, и существенно сокращает объем обрабатываемой информации. Так данные NetFlow за минуту для всей сети СТАУ составляют в среднем около двух мегабайт, в то время как объем переданного за это время трафика – в среднем 700 мегабайт.

Кроме того, данные по NetFlow хранятся, что позволяет провести анализ инцидентов и найти источники и механизмы атак.

Важным параметром разработанного программно-аппаратного комплекса является предельное число потоков, генерируемое единичным IP-адресом, т.к. данный параметр определяет уровень отсеечения. В работе делается попытка определить требования к веб-хостингу, предъявляемые с точки зрения устойчивости к наиболее распространенным типам DDoS-атак. Для двух таких типов DDoS-атак ниже приведены формулы по расчету числа компьютеров K , необходимых для вывода из строя веб-сервера.

1. Вторжения, направленные на перегрузку информационных ресурсов сервера:

$$K = \frac{Z}{l \cdot T^s},$$

где Z – число одновременно обслуживаемых веб-сервером запросов, l – частота, с которой один атакующий компьютер отправляет запросы веб-серверу, T^s – время формирования одной веб-страницы.

2. Вторжения, направленные на переполнение канала связи.

$$K = \frac{3 \cdot C}{d \cdot S^f},$$

где C – суммарная емкость канала, d – уровень обнаружения, измеряемый в потоках в минуту, и S^f – средний размер одного потока, равный среднему размеру файла. Коэффициент 3 выбран для того, чтобы сгладить суточные пиковые нагрузки.

Разработанный программно-аппаратный комплекс по защите от сетевых вторжений был внедрен в сети СГАУ в начале 2011 года и функционирует до сих пор. За этот период было отражено несколько DDoS-атак на сайты, размещенные на защищаемом хостинге.

Основные результаты диссертации

Предложена модель Интернет-трафика на уровне потоков, которая описывает текущее состояние сети двумя переменными: загрузкой сети и числом активных потоков в ней.

Получено уравнение для рабочей области на плоскости сетевых состояний, последовательный выход за пределы которой двух или более значений свидетельствует об аномальном состоянии сети.

Проведена экспериментальная проверка модели на различных научно-образовательных сетях, которая подтвердила зависимость формы рабочей области от переменных модели (загрузки канала и числа активных потоков).

Проведена экспериментальная проверка модели на возможность обнаружения различных аномальных состояний, и в частности, сетевых вторжений двух типов: сканирование портов и DDoS-атаки. Данная проверка подтвердила работоспособность предложенной модели.

Разработан метод обнаружения IP-адресов, осуществляющих несанкционированное вторжение двух типов: сканирование портов и DDoS-атаки, – который заключается в многократном росте активных потоков, генерируемых атакующими IP-адресами.

Разработана методика определения уровня отсечения подозрительных IP-адресов по числу генерируемых потоков.

Разработан комплекс программно-аппаратных средств, который реализует защищенное информационное пространство для размещения Интернет-ресурсов.

Разработанный комплекс программно-аппаратных средств установлен и запущен в эксплуатацию в одном из сегментов сети СГАУ.

Проведены успешные испытания разработанного программно-аппаратного комплекса в процессе работы веб-хостинга в сети СГАУ.

Основные результаты опубликованы

В журналах, рекомендованных ВАК:

1. Sukhov, A.M. Active flows in diagnostic of troubleshooting on backbone links [Text] / A.A. Galtsev, A.M.Sukhov, D.I. Sidelnikov, A.P. Platonov, M.V. Strizhov // Journal of High Speed Networks . – 2011. – Vol. 18. – №. 1. – P. 69-81.

2. Гальцев, А.А. Обнаружение сетевых атак на потоковом уровне [Текст] / А.А. Гальцев, А. М. Сухов // Телекоммуникации – М., №12, 2011. - С. 21-26.

3. Сухов, А.М. Функция распределения задержки пакетов в глобальной сети для задач теории управления [Текст] / А.А. Гальцев, А.М. Сухов, Н.Ю. Кузнецова, А.К. Первицкий // Телекоммуникации – М., №12, 2010. - С. 10-16.

В рецензируемых периодических изданиях, реферируемых Web of Science:

4. Galtsev, A.A. Network attack detection at flow level [Text] / A.A. Galtsev, A.M.Sukhov // Proceedings of the 11th International Conference on Next Generation Wired/Wireless Networking NEW2AN/ruSMART 2011, Lecture Notes in Computer Science. – Springer-Verlag, Berlin, 2011. – Vol. 6869. – P. 326–334.

В других изданиях:

5. Гальцев, А.А. Обнаружение DDoS-атак на основе потоковых моделей трафика [Текст] / А.А. Гальцев // Всероссийская молодежная научная конференция с международным участием “X Королёвские чтения”, сборник тезисов, Самара, 2009. - С. 283-284.

6. Гальцев, А.А. Сравнительные характеристики научно-образовательных сетей [Текст] / А.А. Гальцев // Труды XIII Всероссийской научно-методической конференции “Телематика 2009”, СПб, 2009. - С. 302-305.

7. Гальцев, А.А. Сравнительные характеристики научно-образовательных сетей [Текст] / Гальцев А.А. // Конференция представителей региональных научно-

образовательных сетей "RELARN-2009", сборник тезисов докладов, М.-СПб, 2009. - С. 45-49.

8. Гальцев, А.А. Технология администрирования учетных записей пользователей в компьютерной сети ТФ СГАУ [Текст] / Гальцев А.А., Сагатов Е.С., Султанов Т.Г. // Городская научная студенческая конференция "Молодежь. Наука. Общество." – сборник тезисов, Часть II, Тольятти, 2009. - С. 77.

Гальцев Алексей Анатольевич

СИСТЕМНЫЙ АНАЛИЗ ТРАФИКА

ДЛЯ ВЫЯВЛЕНИЯ АНОМАЛЬНЫХ СОСТОЯНИЙ СЕТИ

Автореф. дисс. на соискание учёной степени кандидата техн. наук

Подписано в печать 28.02.2013. Заказ № 0753

Формат 60x84/16. Усл. печ. л. 1. Тираж 100 экз.

Отпечатано с готового оригинал-макета

445010, Тольятти, Советская, 78, Типография Ника